

Transformación y Desafíos de Seguridad en "Financiera Progresar"

Marco Normativo, Gobernanza de TI, Políticas de Asignación y Gestión de Riesgo Tecnológico

1. CONTEXTO INSTITUCIONAL

"Financiera Progresar" es una entidad crediticia supervisada que atiende a miles de clientes. Con el propósito de agilizar sus operaciones y modernizar su infraestructura tecnológica, la Junta Directiva autorizó la migración paulatina de sus aplicaciones críticas a entornos virtuales y la subcontratación de un Proveedor de Servicios de Seguridad Administrados (MSSP) para la monitorización de su perímetro de red.

2. DIAGNÓSTICO DE INCIDENTES OPERATIVOS Y DE CONTROL

Incidente A: Estaciones de Trabajo y Uso Aceptable (AUP)

- En la sucursal central, varios colaboradores adquirieron e instalaron aplicaciones ofimáticas y herramientas de descarga de forma autónoma en sus equipos asignados para "agilizar sus reportes semanales".
- Un oficial de crédito conectó una memoria USB personal para sustraer un listado confidencial de clientes a su computadora personal, ocasionando la infección por malware de la red local y la fuga temporal de bases de datos.
- Múltiples auxiliares comparten una misma cuenta de usuario genérica para registrar operaciones en el sistema transaccional con el fin de evitar los bloqueos automáticos de sesión por inactividad.

Incidente B: Adquisiciones No Planificadas y Soporte Técnico Informal

- La jefatura comercial tramitó directamente la compra de diez escáneres especializados contactando a un proveedor sin consultar al Área de Informática. Al recibirse, se detectó que eran incompatibles con el sistema operativo institucional y que en bodega existían equipos idénticos disponibles y desocupados.
- Las solicitudes de soporte técnico se canalizan verbalmente o vía llamadas informales a técnicos de guardia, omitiendo el registro de órdenes de solicitud, el diagnóstico escalonado por niveles y la firma de actas de conformidad.

Incidente C: Externalización de Servicios (Outsourcing) y Gobernanza

- Se contrató a una empresa externa para el desarrollo y alojamiento en la nube de un módulo de cobro mediante un contrato básico sin acuerdos de nivel de servicio (SLA) con penalizaciones, ni custodia del código fuente (*Escrow*).

- El servicio sufrió una caída crítica de 48 horas continuas y el proveedor negó el acceso al equipo de auditoría interna para inspeccionar las bases de datos y registros lógicos.
- La Junta Directiva alegó formalmente que la responsabilidad legal por la indisponibilidad y fuga de información corresponde 100% a la empresa proveedora.

3. GUÍA DE ANÁLISIS Y PREGUNTAS ABIERTAS

Instrucciones: Analice el caso planteado con base en las normas de riesgo tecnológico (SIBOIF/CONAMI), gobernanza de TI y políticas de uso aceptable. Fundamente técnicamente cada respuesta.

Bloque 1: Asignación, Uso Aceptable y Soporte Técnico

1. **Perfil de Usuario y AUP:** Identifique las fallas de control que permitieron la instalación libre de software y el uso de puertos USB. Explique cómo debe estructurarse la asignación formal de hardware/software mediante la definición de *Perfiles de Usuario* y restricciones lógicas.
2. **Procedimiento Formal de Soporte:** Describa el ciclo de vida correcto que debe seguir una solicitud de soporte técnico: desde el registro inicial en Helpdesk (Nivel 1), escalamiento, hasta el cierre con firma de conformidad y archivo en el expediente del equipo.

Bloque 2: Adquisición de Tecnología y Principios de Gestión

1. **Flujo Integral de Compras:** Detalle las etapas metodológicas obligatorias para la adquisición de hardware/software (justificación técnica, validación de inventario ocioso, comité evaluador/terna y RFP). ¿Por qué la compra de los escáneres violó los principios de rentabilidad (ROI) y eficiencia?

Bloque 3: Seguridad Organizacional y Contrataciones Externas

1. **Responsabilidad Institucional en Outsourcing:** Analice la validez de la postura de la Junta Directiva respecto a trasladar la responsabilidad total al proveedor. ¿Qué establece la normativa sobre la delegación de responsabilidades ante terceros?
2. **Cláusulas Contractuales Indispensables:** Explique la importancia de al menos cuatro cláusulas omitidas en el contrato del módulo de cobro (SLA, NDA, Delimitación de Propiedad, Custodia de Código Fuente/ Escrow, y Facultad de Auditoría).

Bloque 4: Gobernanza Multinivel y Factor Humano

1. **Políticas Multinivel (Estratégico, Táctico y Operativo):** Clasifique las medidas correctivas que deben implementarse en los tres niveles de la estructura organizativa para restablecer el control.
2. **Principio de No Repudio y Controles Lógicos:** ¿Por qué el uso de cuentas genéricas vulnera el principio de no repudio? Proponga un plan que combine capacitación y controles tecnológicos automatizados (MFA, bloqueo por inactividad).

Criterios de Evaluación Pedagógica: Claridad conceptual, dominio del marco normativo y de gobernanza, capacidad crítica de resolución de incidentes reales y solidez en las propuestas de mitigación técnica y procedimental.